Cybersecurity Risk Assessment Framework for Small Businesses (SMEs)

Evaluating risks and proposing practical mitigation strategies for small and medium enterprises

Why Focus on Small & Medium Enterprises?

Prime Targets

SMEs are increasingly becoming the focus of sophisticated cyberattacks as threat actors exploit perceived vulnerabilities

Limited Resources

Most lack the robust security budgets and dedicated IT staff that larger enterprises can afford to maintain

Catastrophic Impact

A single cyber incident can lead to devastating financial and reputational damage that threatens business survival

Our goal: Provide a structured, scalable risk assessment and mitigation framework specifically designed for SME constraints and capabilities.

Identifying the Threats

Understanding the most common cybersecurity risks that threaten SMEs allows organisations to prioritise their defensive efforts effectively.

Phishing & Social Engineering

Tricking employees into revealing sensitive credentials and confidential data through deceptive emails and messages

Ransomware Attacks

Encrypting crucial business data and demanding substantial payment to restore access to operations

Insider Threats

Accidental data leaks or intentional sabotage by current or former staff members with access privileges

Weak Authentication

Reliance on single, easily guessable passwords without multi-factor verification across systems

Unsecured Remote Access

Vulnerabilities introduced by remote work environments, including public Wi-Fi and personal devices

A Structured Approach

Adapted from NIST Cybersecurity Framework

01

Identify

Comprehensive inventory of all critical assets including hardware, software, data, and systems requiring protection

02

Protect

Implement robust safeguards such as access control, employee training programmes, and firewall deployment

03

Detect

Establish continuous monitoring systems to identify security events and anomalies early in the attack lifecycle

04

Respond

Develop clear action plans to contain, investigate, and mitigate the impact of security incidents

05

Recover

Implement resilient backup and restoration plans to quickly resume normal operations after incidents

Calculating Threat Severity

5×5 Risk Evaluation Matrix

Risk Score = Likelihood (1-5) × Impact (1-5)

Likelihood: Ranging from 1 (Rare) to 5 (Almost Certain)

Impact: Ranging from 1 (Negligible) to 5 (Severe)

Impact

Likelihood	1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe	5 Severe
1 Rare	1	5	6	8	17	25
2 Unlikely	2	6	7	8	20	21
3 Possible	3	9	8	9	21	25
4 Likely	4	10	12	16	20	21
5 Rare	1	2	3	4	5	6

Likelihood

1-4: Low Risk
Minimal impact, unlikely to occur

5-9: Medium Risk
Moderate impact requiring attention

10-16: High Risk
Significant impact needs immediate action

1-4: Low Risk
Minimal impact, unlikely to occur

17-25: Critical Risk
Catastrophic impact demands priority

1-4: Low Risk

Minimal impact, unlikely to occur

5-9: Medium Risk

Moderate impact requiring attention

10-16: High Risk

Significant impact needs immediate action

17-25: Critical Risk

Catastrophic impact demands priority

Defending Your Business

Core Risk Mitigation Strategies

Multi-Factor Authentication

Essential protection for all critical systems using time-based tokens or biometric verification

Automated Off-site Backups

Implement the 3-2-1 backup rule: 3 copies, 2 different media, 1 off-site location

Endpoint Detection & Response

Next-generation behavioural antivirus combined with modern firewall technology

Security Awareness Training

Regular employee training sessions and simulated phishing campaigns

Patch Management

Automated software updates to fix known vulnerabilities across all systems

Case Study A

High Risk Scenario: Retail Point-of-Sale

Business Profile

Boutique retail store with local point-of-sale system processing customer transactions

Threat Scenario

Ransomware attack propagated through the network via an employee's compromised computer accessing infected email

Risk Evaluation

Likelihood (3) × Impact (4) = **12 (High Risk)**

Mitigation Strategy

- Network segmentation separating PoS from general employee web access
- Deployment of Endpoint Detection & Response (EDR) software
- Regular system backups tested weekly

Initial Risk

High Risk requiring immediate action

Reduced Risk

Low Risk after mitigation

Case Study B

Critical Risk Scenario: Financial Data Handling

Business Profile

10-person accounting firm managing sensitive tax records and financial data for local businesses

Threat Scenario

Credential harvesting via spear-phishing emails posing as the IRS, targeting senior accountants with access to client data

Risk Evaluation

Likelihood (4) × Impact (5) = **20 (Critical Risk)**

Mitigation Strategy

- Enforced strict multi-factor authentication on all systems
- Advanced email filtering and sandboxing technology
- Specific verification protocols for financial transactions

Initial Risk

Critical Risk requiring priority

Reduced Risk

Medium Risk with early containment

Case Study C

High Risk Scenario: Distributed Workforce

Business Profile

Fully remote marketing agency using personal networks and SaaS platforms for collaborative work

Threat Scenario

Man-in-the-Middle (MitM) attack over unsecured public Wi-Fi intercepting client communications and credentials

Risk Evaluation

Likelihood (4) × Impact (3) = **12 (High Risk)**

Mitigation Strategy

- Mandatory corporate VPN usage on untrusted networks
- Zero Trust Network Access (ZTNA) implementation
- Full endpoint device encryption on all employee hardware

Initial Risk

High Risk requiring action

Reduced Risk

Low Risk after mitigation

Key Findings & Next Steps

What the Data Shows

The Human Element

Employee actions remain the weakest link and primary attack vector. Continuous training and awareness programmes are essential for defence.

Basic Hygiene Works

Most risks can be mitigated affordably using foundational tools like MFA, regular patching, and systematic backups.

Communication is Key

Using a matrix helps contextualise technical cyber threats into simple business risks that management can understand and prioritise.

Next Steps for SMEs

- [ ] Adopt a proactive culture of security company-wide

  Make cybersecurity everyone's responsibility, not just IT

- [ ] Consider Managed Service Providers Providers (MSPs)

  Leverage external expertise if in-house IT capabilities are limited

- [ ] Prepare for the worst-case scenario scenario

  Always assume a breach will happen and have a printed incident response checklist ready

Thank you for your attention.